

Phishing Email Investigation – UPS Brand Impersonation / Credential Harvesting Campaign

Incident Type	Email Phishing – Spearphishing Link
Classification	Credential Phishing Campaign
Severity	High
Confidence	High
Evidence ID	E-001
Evidence Source	Rendered .eml — captured in Mozilla Thunderbird
Email Date (UTC)	Fri, 30 Aug 2024, 18:00:52
Analyst	SOC Analyst
Report Status	Final

1. Executive Summary

A phishing email impersonating **UPS** was delivered to a user mailbox via legitimately authenticated Microsoft 365 / Exchange Online infrastructure. The message used a package-delivery lure to drive the recipient toward an embedded link that redirected through the `t.co` URL shortener to **zoomertar.com**, a domain independently classified as **phishing** by threat-intelligence vendors. The email also contained hidden tracking pixels hosted on **199.192.27.195** to confirm mailbox activity.

Although the sending domain (`ali001.sarakzit.za.com`) passed SPF, DKIM, and ARC checks, authentication only confirms the sender controlled that domain — it does not validate the claimed UPS identity. Correlating header forensics, HTML/URL analysis, and threat-intelligence enrichment produces a consistent, high-confidence finding: this is a well-crafted credential-phishing email, not a legitimate UPS communication. No telemetry is available to confirm user interaction or credential loss; the destination site is currently offline, consistent with the short operational lifespan typical of phishing infrastructure. No malicious attachments or executable payloads were identified during the investigation; the campaign relied exclusively on social engineering and credential harvesting through embedded hyperlinks.

2. Evidence Snapshot

Field	Value
Display Name	UPS Partner
Sender (From)	Hoffman_John_49321@ali001.sarakzit.za.com
Return-Path	Hoffman_John_49321@ali001.sarakzit.za.com (matches From)
Subject	Exclusive UPS Partnership Opportunity – Unlock Your Earnings!
Message-ID Domain	dcccd.edu (inconsistent with sender domain)
Sending IP	52.100.0.236 (Microsoft Exchange Online Protection)

Field	Value
Primary Malicious Link	https://t.co/f9tVtkdJm3 → zoomertar.com
Tracking Server	199.192.27.195
Fabricated Tracking Code	IPHON-772-H9B5 (does not match UPS format)

3. Initial Triage Findings

Visual inspection of the rendered email, prior to any header analysis, produced eight independent red flags:

Indicator	Present
Brand impersonation (UPS)	Yes
Display-name spoofing	Yes
Sender domain unrelated to brand	Yes
Subject/body thematic mismatch	Yes
Generic, non-personalized content	Yes
Fabricated / non-standard tracking code	Yes
Oversized single call-to-action button	Yes
Delivery-themed urgency lure	Yes

Assessment: The subject line references a "partnership opportunity / earnings" while the body describes a package delivery — a mismatch typically caused by reuse of a phishing HTML template across unrelated lures. No recipient name, order number, or shipment details are present, which is inconsistent with genuine UPS notifications.

Initial classification: Suspected Phishing — carried forward to full header/infrastructure analysis below.

4. Email Header Forensics

4.1 Identity Fields:

Header	Value	Purpose
From	Hoffman_John_49321@ali001.sarakzit.za.com	Visible sender
Return-Path	Hoffman_John_49321@ali001.sarakzit.za.com	SMTP envelope sender (bounce address)
MAIL FROM (SPF)	ali001.sarakzit.za.com	Domain evaluated for SPF
DKIM Domain (d=)	ali001.sarakzit.za.com	Domain that cryptographically signed the message
Message-ID Domain	dcccd.edu	Domain of the generating mail infrastructure

Finding: From, Return-Path, SPF, and DKIM domains are internally consistent (all ali001.sarakzit.za.com) — the message is not spoofing another organization's domain at the SMTP/authentication layer. However, the Message-ID references an unrelated domain (dcccd.edu), and

none of these authenticated identities have any relationship to UPS. Message-ID mismatches are not proof of phishing on their own (legitimate ESPs like Mailchimp/SendGrid also generate third-party Message-IDs), but combined with the other findings in this report it adds to the weight of evidence.

4.2 Timing

Date header (18:00:52 UTC) is 7 seconds ahead of the first Received timestamp (18:00:59 UTC) — normal SMTP transit time, no evidence of delayed or replayed delivery.

5. Authentication Analysis (SPF / DKIM / DMARC / ARC / CompAuth)

Control	Result	SOC Interpretation
SPF	Pass (client-ip=52.100.0.236)	The IP was authorized to send for ali001.sarakzit.za.com — confirms domain ownership, not legitimacy or brand identity.
DKIM	Pass (d=ali001.sarakzit.za.com)	Message was signed by and unaltered since leaving ali001.sarakzit.za.com. Attacker-owned domains can be signed just as validly as legitimate ones.
DMARC	p=none (monitor-only)	Alignment succeeded because SPF/DKIM both passed, but the domain owner enforces no rejection policy — offers no protection even if authentication had failed.
ARC	Present	Microsoft preserved authentication state across its infrastructure; not itself a trust signal.
CompAuth	Pass (reason=130)	Microsoft's proprietary composite score found the authentication signals internally consistent — this is not a safety/legitimacy verdict.
SCL (Spam Confidence Level)	5	Despite passing every authentication check, Microsoft's content/behavioral analysis still routed the message to Junk.

Key takeaway: A full SPF/DKIM/ARC pass here is explained by the attacker legitimately owning and correctly configuring ali001.sarakzit.za.com on Microsoft 365 — not by any relationship with UPS. Authentication proves *domain control*, never *sender trustworthiness*. This is a growing trend: attackers purchase or compromise Microsoft 365 tenants specifically to inherit Microsoft's IP reputation and bypass authentication-based filtering.

6. Sending Infrastructure Analysis

Component	Value	Assessment
Sending IP	52.100.0.236	Legitimate Microsoft Exchange Online Protection relay — not attacker infrastructure

Component	Value	Assessment
SMTP Relay	APC01-PSA-obe.outbound.protection.outlook.com	Microsoft outbound mail protection service
HELO/EHLO	outbound.protection.outlook.com	Normal, expected Microsoft hostname
Registered Owner (ASN 8075)	Microsoft Corporation	Confirmed via WHOIS/RDAP and VirusTotal

Analyst note: Microsoft only *transported* the message; it did not originate it. A common analyst error is to treat every IP seen in a phishing email as malicious — doing so here would result in incorrectly blocking legitimate Microsoft mail infrastructure. 52.100.0.236 should be used only as a **hunting pivot** (to find related campaign emails relayed through the same tenant), never added to a blocklist.

7. URL, Link & HTML Analysis

7.1 Extracted URLs

#	URL	Function
1	http://199.192.27.195/track/3gNjbl4972...	Hidden 1×1 tracking pixel
2	//199.192.27.195/track/3pMOOi4972...	Hidden 1×1 tracking pixel
3	https://t.co/f9tVtkdJm3	Primary phishing link — bound to every CTA button
4	https://t.co/LP1HzGJj58	Unsubscribe link (adds legitimacy)
5	https://zupimages.net/up/24/35/w45j.png	Remotely hosted UPS-branding image

Redirect chain: t.co/f9tVtkdJm3 → zoomertar.com/0/0/0/a3573072c663c9f13330fb9a30afd7a0/-12 → currently unreachable (404/offline).

The destination being offline **does not weaken the phishing determination** — it reflects the typically short operational lifespan of phishing domains (hours to weeks) once campaigns are detected, sinkholed, or abandoned. The verdict is built on correlated evidence, not live reachability.

7.2 HTML Tradecraft

- Table-based, multi-nested HTML layout for consistent rendering across mail clients (Outlook, Gmail, Apple Mail, Thunderbird) — the same technique used by legitimate marketing platforms.
- Remote-hosted branding image (rather than an embedded attachment) reduces message size and adds an additional tracking opportunity.
- Two invisible tracking pixels pointed at 199.192.27.195, logging recipient IP, timestamp, and user-agent on open — confirming the mailbox is active and human-monitored.
- Minimal spelling/grammar errors and a working unsubscribe link — deliberate design choices that lower recipient suspicion.

7.3 Social-Engineering Techniques

Technique	Evidence	Psychological Trigger
Brand trust	UPS logo, colors, layout	Credibility
Curiosity	"Use your code to track it"	Encourages interaction
Urgency	"Schedule your delivery"	Reduces critical thinking
Authority	Professional formatting	Increases perceived legitimacy
Convenience	Single large CTA button	Drives fast, low-friction clicks

No overt threats ("your account will be deleted") were used — the attacker relies on routine business language, which is a hallmark of more mature phishing operations.

8. Threat Intelligence Enrichment

8.1 zoomertar.com — Phishing Landing Domain

Attribute	Value
VT Community Score	2/91 vendors flagging malicious
Category	Phishing (alphaMountain.ai); also flagged Malicious (Webroot)
Registrar	Name.com, Inc.
Created	2024-05-25
Domain Status	clientTransferProhibited, `redemptionPeriod`
Last Updated	2025-07-08
DNSSEC	Unsigned
A Record	91.195.240.94 (TTL 300)
MX Record	mail.pickelhost.com
TXT (SPF)	v=spf1 ip6:fd68:85f0:7c72::/48 -all
Current TLS Cert	DigiCert "Encryption Everywhere DV" — valid 2025-05-27 → 2026-05-26
JARM	3fd3fd000000000000043d3fd3fd43d79451d8c63b099ac afdbabb24551d0e6

Passive DNS (historical resolutions):

Date	IP	Detections
2024-05-26	91.195.240.94	3/91
2024-07-16	94.154.173.144	0/91
2024-09-06	176.106.102.89	0/91

Historical WHOIS / SSL: 4 historical WHOIS records and 4 historical certificates, all consistently issued to zoomertar.com under Name.com; registrant data redacted from mid-2025 onward.

Assessment: The domain's entry into **Redemption Period** (i.e., allowed to lapse/expire rather than being renewed) is a textbook indicator of disposable phishing infrastructure: register → deploy campaign →

harvest → abandon. Multiple IP changes across its lifetime indicate hosting migration, consistent with attacker infrastructure churn. A valid HTTPS certificate here only improves user trust — it is not an indicator of legitimacy.

8.2 199.192.27.195 — Tracking Pixel Server

Attribute	Value
VT Community Score	0/91 (no current AV detections)
ISP / Owner	Namecheap, Inc.
Usage Type	Data Center / Web Hosting / Transit
ASN	AS22612
Network	199.192.16.0/20 (RIR: ARIN)
Location	Phoenix, Arizona, US
AbuseIPDB	0 reports, 0% confidence of abuse (clean report history)
Observed Hostname	www.e2022shirai-amazon.ygto.com (Amazon-themed, unrelated to this IP's actual function)
A/AAAA/MX/NS DNS records	None found on direct lookup
Current TLS Cert (JARM 15d3fd16...)	Issued to `rumahzeus.site` (Sectigo), valid 2023-11-05 → 2024-12-05 — a domain unrelated to this campaign

Passive DNS (135 historical resolutions on this infrastructure) — notable entries:

paypal.ltd (PayPal typosquat) · marktplaats-verifieren.nl (fake Dutch marketplace "verification" phish) · harvestbigapp.com · tebakangkagtatogel.com, prediksigta.site, prediksijitugtatoget.com, prediksimantapgta.com, predikjitungta.com (Indonesian gambling/prediction scam cluster) · www.shiraiserve-amazon.zzux.com (9/91 detections — Amazon-themed phishing, the only entry in this set with active AV flags)

Associated files: 4 email samples (sample-3900.eml, message.eml, sample-3186.eml, noname (11).eml) reference this IP, indicating it recurs across multiple unrelated phishing investigations rather than being a one-off.

Assessment: While the IP itself carries no current malicious detections, its hosting history shows a long, rotating pattern of PayPal typosquatting, fake marketplace verification, Amazon impersonation, and gambling-scam domains going back to 2020. Hosting on a mainstream, reputable provider (Namecheap) is a deliberate choice by threat actors to reduce suspicion and complicate wholesale blocking. This IP should be treated as **shared/rotating scam-hosting infrastructure**, not a single dedicated attacker server.

8.3 ali001.sarakzit.za.com — Authenticated Sender Domain

Attribute	Value
VT Community Score	0/91
Vendor Flags	LevelBlue: Suspicious; all other 90 vendors: Clean
Parent Domain	sarakzit.za.com

Attribute	Value
DNS Records	None resolvable directly (subdomain used for mail authentication only)

Assessment: Low AV detection count is expected and **not exculpatory** — this domain was used specifically because it had no prior negative reputation, allowing it to pass SPF/DKIM cleanly and evade signature-based filtering. Its only connection to the campaign is that it was configured to authenticate and relay the phishing email; it has no legitimate relationship to UPS.

8.4 52.100.0.236 — Sending Relay (Microsoft)

Attribute	Value
VT Community Score	0/91
Owner	Microsoft Corporation
ASN	8075 (Network 52.96.0.0/12)
Reverse DNS	mail-psaapc01hn2236.outbound.protection.outlook.com
AbuseIPDB	12 historical reports, but 0% abuse confidence
Sender/Web Reputation	Neutral; not present on Spamhaus PBL, CBL, or SpamCop blocklists

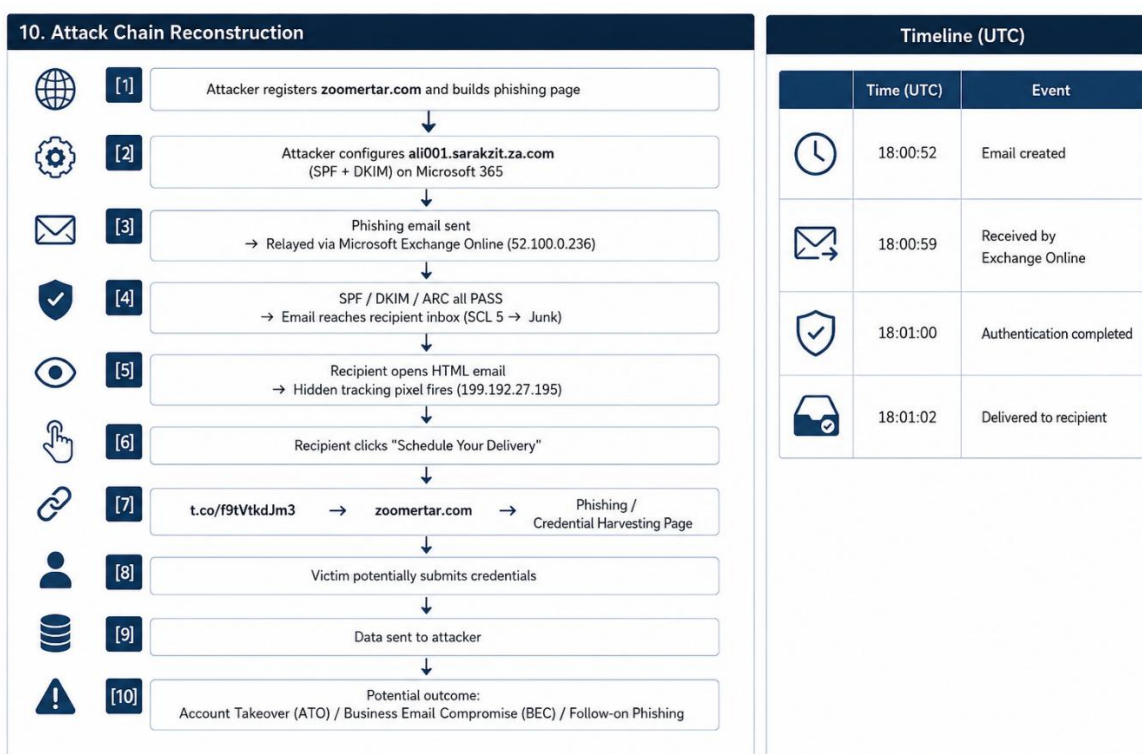
Assessment: Confirmed legitimate Microsoft 365 outbound infrastructure. The 12 historical abuse reports reflect prior spam/phishing campaigns that were *also* relayed through shared Microsoft tenants — not malicious activity by Microsoft itself. **Do not block or blacklist this IP**; use it only as a threat-hunting pivot to locate other emails relayed through the same tenant/timeframe.

9. Indicators of Compromise (IOC) Summary

IOC Type	Value	Role	Verdict
Domain	zoomertar.com	Phishing landing page	Malicious — High Confidence
Domain	ali001.sarakzit.za.com	Authenticated sender domain	Abused / Attacker-Controlled — Medium-High Confidence
IP	199.192.27.195	Tracking pixel server	Suspicious Shared Infrastructure
IP	52.100.0.236	Microsoft Exchange Online relay	Legitimate — Hunting Pivot Only
URL Shortener	t.co (f9tVtkdJm3, LP1HzGJj58)	Redirection / obfuscation	Malicious usage in this campaign
Sender Email	Hoffman_John_49321@ali001.sarakzit.za.com	Phishing sender	Malicious

IOC Type	Value	Role	Verdict
Subject	<i>Exclusive UPS Partnership Opportunity – Unlock Your Earnings!</i>	Campaign identifier	Malicious
Message-ID Domain	dcccd.edu	Anomalous generating infrastructure	Suspicious pivot
Fabricated Tracking Code	IPHON-772-H9B5	Lure prop	Non-conforming to UPS format

10. Attack Chain Reconstruction



Confirmed vs. Inferred: Delivery, authentication behavior, and infrastructure are directly observed facts. Victim interaction, credential submission, and account compromise are **not confirmed** — no endpoint, identity, or proxy telemetry was available for this sample. These require correlation with EDR/identity logs during response.

11. MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence
Initial Access	Phishing	T1566	UPS-themed HTML email delivered to inbox
Initial Access	Spearphishing Link	T1566.002	Embedded links redirecting via t.co → zoomertar.com

Tactic	Technique	ID	Evidence
Execution	User Execution	T1204	Attack requires recipient to click the CTA button
Credential Access	Input Capture: Web Portal Capture	T1056.007	Landing domain classified as phishing; likely credential harvesting (not confirmed)
Defense Evasion	Trusted Relationship	T1199	Attacker-owned domain fully authenticated (SPF/DKIM/ARC) via Microsoft 365 to bypass filtering
Reconnaissance	Gather Victim Identity Information	T1589	Hidden tracking pixels confirm active/opened mailboxes
Command and Control (<i>potential, unconfirmed</i>)	Application Layer Protocol: Web Protocols	T1071.001	Would occur only if the user browsed to the phishing site post-click

Primary technique for this incident: T1566.002 (Spearphishing Link). Supporting techniques describe surrounding tradecraft and should be cited only alongside their respective evidence, as noted above.

12. Incident Assessment

Category	Assessment
Attack Type	Credential Phishing
Delivery Method	HTML email, embedded links (no attachment, no malware observed)
Initial Access	Successful — email reached the inbox
Authentication Bypass	Achieved via legitimately owned/authenticated attacker domain
Credential Theft	Likely intended; not confirmed
User Interaction	Unknown — no telemetry available
Account Compromise	Not confirmed
Attack Sophistication	Moderate (professional templating, authenticated delivery, tracking; no malware or exploitation)
False-Positive Likelihood	Very Low
Overall Severity	High
Overall Confidence	High

Business impact (potential, unconfirmed): credential theft, Microsoft 365 account takeover, Business Email Compromise, internal lateral phishing, financial fraud, reputational damage.

Scope known: one phishing email, one sender identity, one landing domain, multiple embedded URLs, tracking infrastructure.

Scope unknown: total recipient count, click-through count, campaign duration, any additional infrastructure — recommended for follow-up threat hunting.

13. Containment & Response Recommendations

Immediate containment

- Quarantine/delete the email organization-wide; search for identical sender, subject, URLs, or Message-ID pattern.
- Block sender address and domain (`ali001.sarakzit.za.com`) at the email gateway.
- Block `zoomertar.com` at DNS/web gateway/firewall; add resolved URLs to blocklists.
- Block `199.192.27.195` only if no legitimate dependency exists (shared hosting infrastructure).
- **Do not** block `52.100.0.236` — legitimate Microsoft relay; use only for hunting.

Verification & investigation

- Check mail/security logs (Defender for O365, Sentinel, SEG) for opens, clicks, and pixel fires tied to the campaign IOCs.
- Review endpoint telemetry (EDR/Sysmon) for cached phishing pages, unexpected downloads, or credential-prompt activity.
- Review identity logs (Entra ID sign-ins, MFA registrations, new OAuth consents, password changes) for anomalies following email receipt.

Threat hunting pivots: sender address, `ali001.sarakzit.za.com`, `zoomertar.com`, `199.192.27.195`, subject line, `t.co` redirect pattern. (Hunt using `52.100.0.236` only to locate related campaign emails — do not treat as malicious.)

Detection & hardening

- Enable/strengthen brand-impersonation and anti-phishing policies; enable URL rewriting with time-of-click protection.
- Tag external senders; increase scrutiny of newly observed/low-reputation sending domains and URL shorteners in inbound mail.
- Enforce MFA and Conditional Access; enable risk-based sign-in detection.
- Feed IOCs from Section 9 into SIEM/TIP for ongoing monitoring and campaign-overlap detection.

User awareness: brief staff on delivery-themed phishing lures, the risk of shortened URLs, and how to report suspicious email to the SOC.

14. Detection Opportunities

- Alert on newly observed sender domains.
- Detect UPS brand impersonation.
- Alert on URL shorteners inside inbound emails.
- Alert on hidden tracking pixels.
- Hunt for Message-ID anomalies.
- Hunt for newly registered domains.

15. Lessons Learned

This investigation demonstrates that:

- Passing SPF and DKIM does not imply legitimacy.
- Microsoft cloud infrastructure can be abused.

- URL shorteners obscure final destinations.
- Threat intelligence provides essential context when phishing sites become unavailable.
- Multiple weak indicators together produce high-confidence detection.

15. Final Verdict

Incident Classification: Credential Phishing Campaign (UPS brand impersonation)

Severity: High | **Confidence:** High

The investigation concludes this email is part of a deliberate, moderately sophisticated credential-phishing campaign. The attacker combined a fully authenticated Microsoft 365 sending domain, professional HTML templating, invisible tracking, and a URL-shortener redirect to a threat-intel-classified phishing domain to maximize both deliverability and victim engagement. No evidence confirms that any recipient submitted credentials or that an account was compromised; this incident should nonetheless be treated as high risk pending completion of user, endpoint, and identity verification steps outlined above.